

Threat Modeling Document

AI-Assisted Kill-Chain Emulation for Cloud & Container Security Validation

1. Executive Summary

This document provides a formal threat model for the AI-Assisted Kill-Chain Emulation framework. The purpose is to evaluate adversary behavior against cloud, container, and AI-backed systems in a controlled, authorized laboratory environment. The framework simulates real attacker tradecraft without deploying malware or performing destructive actions, enabling safe validation of security controls such as NGFWs, EDRs, AI threat detection, and cloud posture management.

2. Scope & Assumptions

In Scope:

- Exposed Docker APIs (TCP/2375)
- Container runtime misconfigurations
- Kubernetes unauthenticated endpoints (kubelet read-only)
- Cloud metadata services (AWS/GCP/Azure equivalents)
- AI-driven attack planning and escalation logic

Out of Scope:

- Real malware deployment
- Persistence beyond session lifetime
- Lateral movement into external systems
- Non-authorized targets

3. Assets & Trust Boundaries

Asset	Description	Trust Boundary
Docker Daemon	Container runtime API exposed over TCP	Host ↔ Network
Container Host OS	Underlying host filesystem and kernel	Container ↔ Host
Kubernetes Node	Kubelet endpoints and node services	Cluster ↔ Node
Cloud Metadata Service	Instance identity and credentials	Instance ↔ Cloud Control Plane
AI Planner (LLM)	Autonomous decision engine	User ↔ AI System

4. Threat Actors

- External attacker using internet-wide reconnaissance (e.g., Shodan)
- Cloud-native attacker abusing control plane trust relationships
- Malicious insider with limited network access
- Automated adversary leveraging AI for attack chaining

5. Primary Attack Paths (KillChain)

Reconnaissance: Identify exposed Docker APIs and cloud services via OSINT.

Initial Access: Unauthenticated Docker API access.

Execution: Remote container execution as root.

Privilege Escalation: Abuse container runtime privileges.

Container Escape: Read-only host filesystem mount.

Command & Control (Behavioral): Simulated outbound beaconing patterns.

Exfiltration (Simulated): Metadata and environment enumeration.

6. STRIDE Threat Mapping

Category	Example in Framework
Spoofing	Unauthenticated API access
Tampering	Container execution context abuse
Repudiation	Lack of API audit logging
Information Disclosure	Cloud metadata exposure
Denial of Service	Container resource exhaustion (simulated only)
Elevation of Privilege	Docker host filesystem access

7. Security Controls & Detection Goals

- NGFW detection of abnormal Docker API usage
- EDR alerts on container runtime abuse
- AI detection of autonomous attack chaining
- Cloud audit logging for metadata access
- Behavioral correlation across killchain phases

8. Risk Assessment

Impact: High — full host compromise possible if misconfigurations exist.

Likelihood: Medium-High — exposed container APIs remain common.

Overall Risk: Critical without layered defenses.

9. Recommended Mitigations

- Disable unauthenticated Docker TCP sockets
- Enforce mutual TLS on container APIs
- Harden container runtime permissions
- Restrict cloud metadata access (IMDSv2, equivalents)
- Monitor AI agent behavior and decision boundaries

10. Conclusion

This threat model demonstrates how a modern attacker can chain cloud, container, and AI weaknesses into a full compromise path. The AI■Assisted Kill■Chain Emulation framework provides a safe, auditable, and repeatable method to validate defensive controls before production deployment.